📋 Informe del Proyecto Sprint 2 — Priorización de Alertas SOC

Nombre:	Jose Iván Arango Franco
Fecha:	03/Septiembre/2026

I. Desarrollo — Análisis por Alerta

📌 *Importante: No configuras sistemas ni explotas vulnerabilidades. Observas comportamiento y logs. CloudShare se usa como evidencia contextual, no como prueba definitiva.*

Campo de Análisis	ALT-2024-001 🔴 CRÍTICO Ransomware LockBit 3.0	ALT-2024-002 🟠 ALTO Phishing AiTM / MFA bypass	ALT-2024-003 🔴 CRÍTICO Movimiento lateral (PtH)	ALT-2024-004 🟡 MEDIO Exfiltración DNS Tunneling	ALT-2024-005 🟢 BAJO Escaneo de puertos interno
Fuente de la Alerta ¿Cuál es el origen de la notificación de seguridad?	EDR / CrowdStrike, integrado al SIEM.	Microsoft Defender / Azure AD alerta nativa de identidad en la nube.	SIEM / Wazuh correlacionando Windows Event Logs.	Firewall/Palo Alto NGFW detección de red.	IDS/Suricata detección basada en firma (regla GPL SCAN nmap SYN Scan).
Urgencia y Estado ¿Qué tan urgente es la situación? ¿Está ocurriendo AHORA o es un evento pasado?	No es urgente pero es un ataque grave que ya ocurrió, no es urgente porque no se puede revertir ni deshacer.	Es urgente, lo más probable es que continúe ocurriendo ya que la alerta no ha sido asignada a ningún especialista y podemos suponer que no se han tomado medidas.	Esta alerta ya ha sido asignada a un especialista. Sin embargo es la alerta más preocupante y urgente de todas ya que el controlador de dominio principal ha sido comprometido por el atacante.	Alerta sin asignar a ningún especialista. 14,200 consultas DNS en 45 min (~316/min) vs. baseline 2-5/hora. Anomalía de ~4,000-10,000x. Timestamp 2024-12-10 14:22:37. Urgente ya que podemos suponer que el túnel sigue activo	No es urgente, aunque fue un ataque grave con posibles consecuencias duras, ya pasó y el atacante ya obtuvo lo que buscaba. No se puede hacer nada al respecto.
Activos en Riesgo ¿Qué activos están comprometidos o en peligro? (datos críticos, infraestructura clave)	Host WS-CONTAB-07, IP 192.168.10.47, usuario lgarcia@empresa.com, área de	Cuenta de Azure AD/M365 de jmendez (Director de RRHH). Archivo /RRHH/Nomi	DC-PROD-01 (Controlador de Dominio principal), WS-DESA-12 (equipo de Carlos Ruiz) (origen),	SRV-BD-PROD con acceso a base de clientes de +500,000 registros (declarado en la alerta).	LAPTOP-MKT-03 y cuenta de pvillanueva@empresa.com (Marketing, sin funciones técnicas).

	Contabilidad. Extensiones objetivo: .docx .xlsx .pdf .sql .bak (847 archivos afectados).	na_2024.xlsx (4.2MB) descargado. Buzón de correo con regla de reenvío externo activa a ext_hr_backup@gmail.com	cuenta backdoor svc_backup_adm agregada a Domain Admins, hash NTLM de Administrator robado y reutilizado.	Cuenta svc_database que por diseño no debería generar DNS saliente.	Rango escaneado: 192.168.0.0/16 en puertos SSH/HTTP/HTTPS/SMB/MSSQL/MySQL/RDP.
Falso Positivo ¿Existe alguna explicación legítima o inocente para el comportamiento detectado?	Múltiples IOCs coherentes entre sí: hash de proceso, IP C2 conocida de LockBit, dominio .onion de pago, clave de persistencia en registro, extensión ".lockbit3". Proceso "svchost32.exe" no corresponde al binario legítimo de Windows (svchost.exe). No es justificable de ninguna manera, claramente es una extorsión real con Ransomware	Azure AD marcó explícitamente "Impossible travel" y "Anonymous IP". Dominio de phishing registrado solo 3 días antes. Remitente con dominio typosquatted (micro5oft.com). MFA Result = SUCCESS pero anotado como robado vía AiTM (replay de token). Falso positivo descartado.	Cadena sin explicación benigna posible: hash reutilizado marcado explícitamente, Mimikatz ofuscado en memoria (reflective DLL), creación de cuenta (4720), escalación a Domain Admins (4728) en 2 segundos desde equipo de desarrollador a medianoche.	Dominio registrado solo 8 días antes de la generación de la alerta, sin historial legítimo. Subdominios Base64 de longitud fija (60-120 chars) = firma clásica de DNS tunneling. Cuenta de servicio que nunca genera DNS por diseño. Se descarta explicación legítima o inocente.	Patricia no tiene función técnica (declarado en la alerta). Firma nmap confirmada por IDS lo que indica que no fue Patricia quien desarrolló esta acción. Ocurre a las 16:05:19 (10-dic) lo que deja la duda de que podría ser el resultado de la instalación de una app o software no declarado, pudo ser dentro del horario laboral. Si es producto de un ataque, un Domain Admin ya tiene visibilidad vía LDAP/AD sin necesitar un SYN scan masivo y ruidoso. Si es el mismo actor, motivos plausibles: buscar shadow IT invisible en

					AD, obtener estado real de puertos escuchando, o mantener la sesión de Domain Admin "limpia" delegando el trabajo ruidoso. Si no es el mismo actor, podría ser un evento independiente. No se puede descartar un falso positivo sin más investigación.
Correlación ¿Esta alerta está relacionada con algún otro evento o incidente previo?	Ocurre ~2h19min después de ALT-003 y ~7.5h antes de ALT-002. No comparte IOCs con ninguna. Consecuencia probable de ALT-003, vía despliegue con credenciales de dominio robadas (TTP común en ransomware). No tenemos confirmación técnica del vector de despliegue (PsExec/GPO/WMI con la cuenta comprometida).	Mismo día que ALT-001 y ALT-003, ~7.5h después de ALT-001. No comparte ningún IOC técnico con ninguna otra alerta. Vector (email/social engineering) y plano de identidad (cloud/M365) distintos a las demás. Podría ser parte de una campaña más amplia contra la empresa el mismo día, pero el vínculo con ALT-003 solo sería plausible si existe identidad híbrida (Azure AD	Cronológicamente la más temprana de las 5. No comparte IOCs con ninguna otra alerta.Podría ser la causa raíz de ALT-001 (credenciales de Domain Admin usadas ~2h19min después para desplegar el ransomware). No sabemos si el hash robado o svc_backup_adm se usaron efectivamente para autenticar contra WS-CONTAB-07 o si es el mismo actor detrás de las 5 alertas.	La más tardía de las primeras 4. Host nuevo (SRV-BD-PROD), sin overlap de IOCs con ninguna alerta previa. Podría ser una etapa posterior de la cadena de ALT-003 (dominio comprometido usado para llegar a svc_database). ⚠️ Pero el orden cifrado-antes-que-exfiltración (12h después de ALT-001) es atípico para la doble extorsión clásica, podría indicar un segundo actor	La más tardía de las 5. Host y usuario nuevos (LAPTOP-MKT-03, Marketing), sin overlap de IOCs. Podría ser el actor de ALT-003 pivotando a un tercer host pero un Domain Admin no necesita SYN-scan para inventariar la red vía AD, la conexión no debe asumirse solo por proximidad temporal. No sabemos si el laptop muestra el mismo toolset de ALT-003 (confirmaría

		Connect/ADFS) (no confirmado). No podemos tener certeza sobre si es el mismo actor o un vector completamente independiente. Tampoco si existe infraestructura híbrida que conecte el compromiso on-prem con este incidente cloud.		independiente. No sabemos si SRV-BD-PROD está unido al mismo dominio de ALT-003.Tampoco si es el mismo actor u otro aprovechando el caos.	el mismo actor). Tampoco sabemos si Patricia fue comprometida vía phishing o reutilización de credenciales robadas.
Acción Prioritaria ¿Qué se debe priorizar: Contención, Investigación o Notificación?	Se debe notificar inmediatamente, esta alerta se muestra como nueva y sin asignar a ningún especialista. Lo más seguro es que los dueños de la empresa aún no saben del ataque ni tampoco el usuario comprometido	Se debe priorizar la contención, dado que hay una regla de reenvíos que continúa enviando información sensible de RRHH, lo primero que hay que hacer es detener ese flujo malicioso y luego se puede proceder a notificar para continuar con investigación posterior.	Contención inmediata. Exposición total del dominio, no puede esperar investigación completa ni notificación y respuesta. Se debe contener el ataque de urgencia máxima.	Contención: aún teniendo en cuenta que bloquear al atacante puede darle alerta de que ha sido descubierto y se están tomando acciones en su contra, es mucho más importante cuidar la integridad de los datos. Dado el volumen de datos de clientes y la responsabilidad legal que se puede tener por los mismos, proteger el dato debe pesar más.	Investigación antes que contención dura: el evento ya terminó, la severidad de firma es baja, y aislar el equipo de una empleada tiene costo real si resulta benigno. Verificar rápido solapamiento de IOCs con Alerta 3 antes de escalar la respuesta.
Decisión de Acción ¿Cuál es tu elección de acción para esta alerta específica?	Escalar a caso, con aislamiento de red	Escalar a caso con: (1) revocación inmediata de	Escalar a caso con: (1) deshabilitar svc_backup_a	Escalar a Caso con: (1) establecer sinkhole hacia	Escalar a Caso vinculado explícitamente a

	inmediato del host (no apagarlo, para preservar evidencia forense en RAM).	sesión/token, (2) eliminación de la regla de reenvío, (3) reseteo de credenciales, (4) bloqueo del dominio/IPs de phishing.	dm, (2) resetear krbtgt dos veces, (3) aislar WS-DESA-12, (4) buscar otros usos del hash robado en todo el dominio.	con el dominio e IP para evitar alertar, (2) rotar credenciales de svc_database, (3) preservar logs DNS ya capturados, (4) revisar procesos en SRV-BD-PROD , (5) notificar Legal/Compliance por volumen de registros de clientes.	ALT-2024-003 para re-triaje conjunto, con verificación técnica rápida (EDR del laptop) antes de decidir intensidad de contención

II. Alertas por Analizar (referencia)

ID de Alerta	Severidad	Descripción del Incidente	Tipo de Amenaza
ALT-2024-001	🔴CRÍTICO	Cifrado de 847 archivos en WS-CONTAB-07 mediante LockBit 3.0, con conexión activa a servidor C2. Evento puntual ya materializado; posible consecuencia de credenciales de dominio comprometidas en ALT-2024-003.	Malware
ALT-2024-002	🔴CRÍTICO	Robo de sesión M365 vía ataque AiTM con evilginx2, evadiendo MFA. Exfiltración activa de nómina y directorio de empleados, con regla de reenvío de correo persistente aún vigente.	Phishing
ALT-2024-003	🔴CRÍTICO	Pass-the-Hash desde WS-DESA-12 hacia el Controlador de Dominio, con creación de cuenta backdoor escalada a Domain Admins en segundos. Compromiso de mayor alcance del conjunto: riesgo latente sin techo definido sobre todo el dominio.	Intrusión
ALT-2024-004	🟠 ALTO	Exfiltración vía DNS tunneling desde SRV-BD-PROD hacia dominio registrado 8 días antes, con volumen ~4,000x sobre el baseline. Servidor con acceso a base de clientes de +500,000 registros.	Exfiltración
ALT-2024-005	🟡 MEDIO	Escaneo SYN masivo hacia toda la red interna desde laptop de un usuario sin función técnica. Origen y motivo aún sin confirmar: posible pivote del actor de ALT-2024-003, mal uso interno, o herramienta no autorizada.	Reconocimiento

III. Conclusión y Priorización

Elemento	Tu respuesta
Alerta Prioritaria **¿A cuál alerta le darías prioridad de atención y por qué?** **[Indica el ID de alerta y una justificación breve]**	ALT-2024-003. Movimiento Lateral / Compromiso de Domain Admin. Se prioriza sobre las demás no por ser la de mayor daño ya visible (ese honor lo tiene técnicamente ALT-001 o ALT-002 en términos de impacto materializado), sino porque representa riesgo potencial latente sin techo: con privilegios de Domain Admin activos y sin confirmación de contención, el atacante puede en cualquier momento replicar, ampliar o superar el daño de cualquiera de las otras 4 alertas contra cualquier otro activo del dominio.
Qué sabes **Resume la información confirmada sobre la alerta priorizada.** **[Hechos confirmados por los logs o el contexto del activo]**	Se detectó reutilización de hash NTLM (Pass-the-Hash) desde WS-DESA-12 hacia el Controlador de Dominio DC-PROD-01. Se creó una cuenta backdoor (svc_backup_adm) y se agregó al grupo Domain Admins en un lapso de 2 segundos (23:58:14–23:58:16). Se detectó Mimikatz ofuscado (m1m1k4tz.exe) ejecutándose en memoria vía reflective DLL, e Impacket secretsdump.py en el mismo host. El evento es cronológicamente el más temprano de las 5 alertas (23:58:02, 9-dic), y el estado actual es "EN PROGRESO", ya asignado a un analista.
Qué no sabes **Identifica la información crítica que aún falta por determinar.** **[Lagunas de información, datos no disponibles]**	Si la cuenta svc_backup_adm ha sido deshabilitada o sigue activa en este momento. El alcance exacto de lo extraído por secretsdump.py Cómo se comprometió originalmente WS-DESA-12 (el punto de entrada real de toda la cadena). Si las credenciales robadas aquí fueron efectivamente el vector usado para desplegar el ransomware de ALT-001. Si el atacante ha usado su alcance para comprometer más usuarios o dispositivos dentro de la red Qué acciones ha tomado el especialista ya asignado
Supuestos **Detalla los supuestos que estás haciendo para tomar tu decisión.** **[Qué estás asumiendo ante la información incompleta]**	Si secretsdump.py corrió contra el DC, probablemente se extrajo la base completa de credenciales del dominio (NTDS.dit), no solo el hash de Administrator. Que el atacante mantiene, hasta que se demuestre lo contrario, la capacidad de generar nuevos backdoors o desplegar payloads adicionales en cualquier sistema unido al dominio. Que el estado "EN PROGRESO" no garantiza que la amenaza esté contenida, solo que un analista la está trabajando. Que este ataque, fue la puerta de entrada para todos los demás ataques posteriores sean del mismo atacante o de uno diferente.
Elección de Acción **Argumenta por qué elegiste actuar de esa manera.**	Contención, sin ambigüedad, por encima de Investigación o Notificación. La justificación es estructural: con Domain Admin comprometido, cada minuto adicional de exposición multiplica el radio de daño posible sobre activos que ni siquiera sabemos

[Contención / Investigación / Notificación — y por qué]	que están en riesgo todavía. Investigar a fondo el alcance (qué se extrajo, cómo se originó) es necesario, pero no puede preceder a cortar el acceso activo. Se ejecutan en paralelo, con contención primero: deshabilitar svc_backup_adm, resetear krbtgt (dos veces), y aislar WS-DESA-12, preservando evidencia de memoria antes de cualquier apagado para evitar perder información valiosa de logs y registros.
Reflexión final **Si solo tuvieras una hora de turno, ¿en qué la invertirías y por qué?** **[Responde en tono de analista SOC: conciso, neutro, basado en hechos]**	Si solo tuviera una hora de turno, la invertiría íntegramente en confirmar y ejecutar la contención de ALT-003: verificar si la cuenta svc_backup_adm sigue activa y deshabilitarla, iniciar el reseteo de krbtgt, y aislar WS-DESA-12 por red. No usaría ese tiempo en investigar el alcance completo ni en las otras 4 alertas. Con Domain Admin potencialmente aún accesible, cualquier minuto invertido en otra parte es tiempo en que el atacante puede reabrir o ampliar el compromiso, haciendo irrelevante cualquier avance logrado en las demás alertas.

🗒️ *Recuerda: el Sprint 2 no trataba de 'encontrar atacantes', sino de aprender cómo los analistas deciden dónde mirar primero. Este informe es donde ese pensamiento se hace explícito.*